

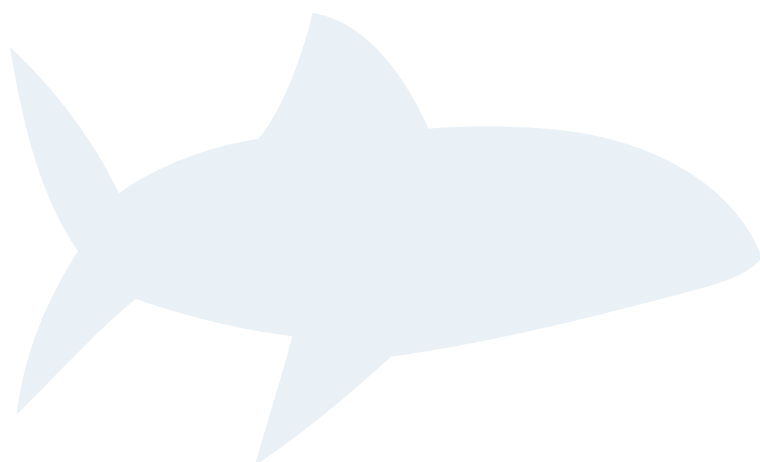


External Security Assessment

Endpoint review — **yornik.eu**

Assessment date	2026-09-28 (revised 2026-09-29)
Type	Non-intrusive external review — passive recon, TLS and HTTP inspection
Authorization	Owner-authorized assessment of an owned domain
Companion	2026-09-28_overall.pdf — estate-wide overview
Classification	Confidential — internal

This report records read-only external observations. No intrusive testing was performed: no exploitation, no brute-force, no port scanning and no authentication bypass. Section 6 gives the tools and the procedure for the owner to run the active phases in a controlled window.





1. Executive summary

This report covers an external review of the **yornik.eu** endpoint. The review used passive reconnaissance and read-only HTTP and TLS inspection. The public posture of the endpoint is strong.

The site enforces HTTPS and serves TLS 1.3 with a valid ECDSA P-384 certificate. It sets a strict Content-Security-Policy and HSTS with preload. It does not expose `/.git/config`, `/.env` or `/server-status`. It disables the TRACE method. Requests reach it only through 2 hardened edge hosts that apply rate limiting and a fail2ban filter.

The review found no high and no medium severity issue on this endpoint. It found 4 low and 3 informational items. The main items are the subdomain inventory published in `security.txt`, an incomplete DMARC policy and a disclosed server version.

Findings by severity

0 High	0 Medium	4 Low	3 Info
-----------	-------------	----------	-----------

Severity reflects external impact on this endpoint. It is not a CVSS score.

2. Scope and authorization

The domain owner requested this assessment of a domain they control. The scope is the public web endpoint of yornik.eu and its public DNS records.

In scope	yornik.eu HTTPS endpoint; public DNS records for yornik.eu
Out of scope	Subdomains (see the companion report); third-party services; any active attack
Method	DNS-over-HTTPS queries, TLS handshake inspection, HTTP header inspection, read-only GET checks
Limits	External view only. No credentials. No internal access. No source review.

3. Methodology

The assessment follows the reconnaissance and analysis phases of the Penetration Testing Execution Standard (PTES) and the OWASP Web Security Testing Guide (WSTG). This engagement ran the passive phases only.

Phase	Reference	Run here
1. Passive reconnaissance (DNS, certificates)	PTES Intelligence Gathering	Yes
2. Transport security (protocols, ciphers, certificate)	OWASP WSTG-CRYP	Yes
3. HTTP configuration (headers, methods, redirects)	OWASP WSTG-CONF	Yes
4. Information exposure (well-known paths, metadata)	OWASP WSTG-INFO	Yes
5. Active scanning (ports, service versions)	PTES Vulnerability Analysis	No — owner runs
6. Application testing (injection, auth, session)	OWASP WSTG-INPV / ATHN / SESS	No — owner runs
7. Exploitation	PTES Exploitation	No — owner runs



4. Findings

F-01 LOW Subdomain inventory disclosed in security.txt

Observation. /.well-known/security.txt lists Canonical URLs for many hosts, including passwords.yornik.eu, secrets.yornik.eu, argocd.fedishark.eu and grafana.fedishark.eu. This hands an attacker a map of the estate with no scanning.

Recommendation. Keep only the canonical entries a researcher needs. Move the full host list out of the public file. Confirm each named host requires authentication.

F-02 LOW DMARC policy has no reporting

Observation. The record is v=DMARC1; p=quarantine;. It has no rua aggregate report address and no alignment tags. Without reports the owner cannot see spoofing attempts or misconfiguration.

Recommendation. Add an rua address. Confirm SPF and DKIM alignment. Move to p=reject once the reports are clean.

F-03 LOW No DKIM record at common selectors

Observation. Queries for the selectors default, google, selector1, selector2, mail and k1 returned no TXT record. Mail sends through Amazon SES, which uses its own rotating CNAME selectors, so signing can still be active under a name not queried here.

Recommendation. Confirm SES DKIM signing is active and aligned. Verify that outbound mail is signed.

F-04 LOW Web server version disclosed

Observation. The response sets server: nginx/1.31.1. The exact version lets an attacker match known issues to the server without probing.

Recommendation. Set server_tokens off; in the nginx configuration. This is a small gain; patching remains the control that matters.

F-05 INFO Deprecated X-XSS-Protection header set

Observation. The response sets x-xss-protection: 1; mode=block. Modern browsers ignore this header, and in older ones it can introduce a side channel. The header comes from browserXssFilter on the shared Traefik middleware, so it appears estate-wide.

Recommendation. Remove browserXssFilter from the shared middleware. The Content-Security-Policy already provides the stronger control.

F-06 INFO DNSSEC state not confirmed externally

Observation. The domain uses Cloudflare name servers. The passive checks did not confirm a signed zone. Without DNSSEC, an attacker who can poison a resolver can redirect the name.

Recommendation. Confirm DNSSEC is enabled for yornik.eu in Cloudflare. Enable it if it is off.



F-07

INFO

SPF uses a soft fail

Observation. The SPF record ends with ~all. A receiver can still accept mail that fails SPF. This is common and acceptable, but weaker than a hard fail.

Recommendation. Once DMARC reporting confirms every legitimate sender, change ~all to -all.

5. Controls that work well

The review confirmed these controls from the external view. The edge controls are applied by the shared Traefik middleware and the jump hosts, so they protect this endpoint even though they are not configured on it directly.

Control	Evidence
HTTPS enforced	http://yornik.eu returns 308 to the HTTPS URL.
HSTS with preload	max-age=31536000; includeSubDomains; preload
Modern TLS	TLS 1.3, TLS_AES_128_GCM_SHA256, X25519 key exchange.
Valid certificate	CN=yornik.eu, Let's Encrypt, ECDSA P-384, chain verified.
Strict CSP	default-src 'self'; object-src 'none'; frame-ancestors 'none'; no inline script.
Clickjacking defence	x-frame-options: DENY and frame-ancestors 'none'.
Rate limiting	Shared Traefik middleware: 300 average, 600 burst.
fail2ban at the edge	A fail2ban middleware is attached at the edge, plus fail2ban on the 2 jump hosts.
No direct cluster exposure	Traffic enters via HAProxy L4 on 2 edge hosts, then a Tailscale mesh. The cluster is not reachable directly.
No sensitive paths	/.git/config, /.env, /server-status, /wp-login.php return 404.
TRACE disabled	TRACE returns 405.
CAA records set	Issuance restricted to 5 named authorities.
Signed security.txt	The published file is PGP-signed, and CI verifies the signature.



6. Running the active phases

The owner can run the active phases against hosts they own. Run them from a controlled network inside a planned window.

WARNING: An active scan can slow a service or trigger an alert. Tell any hosting provider first where their terms require it.

Phase	Tool	Purpose
Port and service discovery	nmap	Map open TCP/UDP ports and service versions.
TLS deep check	testssl.sh, sslyze	Enumerate every protocol, cipher and certificate weakness.
Header posture	Mozilla Observatory	Grade the header configuration independently.
Application scan	OWASP ZAP, Burp Suite	Crawl and test for common web flaws.
Template checks	nuclei	Run a broad set of checks for known issues.
Subdomain discovery	subfinder, amass	Find hosts reachable but not documented.
Content discovery	ffuf, gobuster	Find hidden paths and backup files.
Email and DNS posture	dnsrecon, MXToolbox	Check DNSSEC, SPF, DKIM and DMARC.

Example commands

```
nmap -sS -sV -Pn -p- --min-rate 2000 <edge-ip>
testssl.sh --full https://yornik.eu
nuclei -u https://yornik.eu -severity low,medium,high,critical
subfinder -d yornik.eu | httpx -status-code -title -tech-detect
ffuf -u https://yornik.eu/FUZZ -w wordlist.txt -mc 200,301,302,401,403
```

7. Prioritized recommendations

1. Trim the subdomain list in `security.txt` to what a researcher needs. (F-01)
2. Add a DMARC rua address; move to `p=reject` and `-all` once reports are clean. (F-02, F-07)
3. Confirm Amazon SES DKIM signing is active and aligned. (F-03)
4. Confirm DNSSEC is enabled in Cloudflare. (F-06)
5. Hide the nginx version and drop `browserXssFilter`. (F-04, F-05)
6. Run the active phases in Section 6 in a planned window and record the result.

8. Evidence appendix

Collected 2026-09-28; re-checked 2026-09-29 with no change observed.

HTTP response headers

```
HTTP/2 200
content-security-policy: default-src 'self'; base-uri 'self';
  frame-ancestors 'none'; form-action 'self'; object-src 'none';
  script-src 'self'; style-src 'self'; img-src 'self' data;;
  font-src 'self' data;; connect-src 'self'; upgrade-insecure-requests
strict-transport-security: max-age=31536000; includeSubDomains; preload
x-content-type-options: nosniff
x-frame-options: DENY
referrer-policy: no-referrer
```



```
server: nginx/1.31.1
```

TLS handshake

```
TLSv1.3 / TLS_AES_128_GCM_SHA256 / X25519
subject: CN=yornik.eu
issuer: C=US; O=Let's Encrypt; CN=YE2
expires: Nov 26 10:48:40 2026 GMT
key: EC secp384r1 (384 bit) verify: ok
```

DNS records

```
A/AAAA: 77.42.94.152, 78.47.240.158,
        2a01:4f8:1c19:60c2::1, 2a01:4f9:c014:e6de::1
MX: 10 inbound-smtp.eu-west-1.amazonaws.com.
NS: vick.ns.cloudflare.com. / michelle.ns.cloudflare.com.
TXT: v=spf1 include:amazonses.com ~all
_dmarc: v=DMARC1; p=quarantine;
CAA: letsencrypt.org, digicert.com, pki.goog, ssl.com, comodoca.com
```

Path checks

```
404 /.git/config 404 /.env 404 /server-status
404 /admin 404 /wp-login.php
200 /robots.txt 200 /sitemap.xml
200 /.well-known/security.txt
405 TRACE 405 OPTIONS
```

End of report. This reflects the external state on 2026-09-29. A later configuration change can change the result.